

Incident and Response Lab 3: Potential Impossible Travel

Explanation

Sometimes corporations have policies against working outside of designated geographic regions, account sharing (this should be standard), or use of non-corporate VPNs. The following scenario will be used to detect unusual logon behavior by creating an incident if a user's login patterns are too erratic. "Too erratic" can be defined as logging in from multiple geographic regions within a given time period.

Whenever a user logs into Azure or authenticates with their main Azure account, logs will be created in the "SigninLogs" table, which is being forwarded to the Log Analytics Workspace being used by **Microsoft Sentinel**, our **SIEM**. Within **Sentinel**, we will define an alert to trigger whenever a user logs into more than one location in a *7 day time period*. Not all triggers will be true positives, but it will give us a chance to investigate.

In order to generate the necessary logs for you to detect this activity, simply create a new VM if you don't already have one, log into it, and then log into azure (<https://portal.azure.com>) from within your VM. This will trigger a new logon event in some random city on the East Coast (east us 2) somewhere.

Part 1: Create Alert Rule (Potential Impossible Travel)

Design a Sentinel Scheduled Query Rule within Log Analytics that will discover when a user logs in to more than a **certain number** of locations within a **given time period**; for example, trigger if a user logs into **2 different geographic** regions within a **7 day time period**. (ensure the appropriate logs show up before creating the alert rule)

Hint: Use the SigninLogs table.

```
// Locate Instances of Potential Impossible Travel
let TimePeriodThreshold = timespan(7d); // Change to how far back you want to look
let NumberOfDifferentLocationsAllowed = 2;
SigninLogs
| where TimeGenerated > ago(TimePeriodThreshold)
```

```
| summarize Count = count() by UserPrincipalName, UserId, City =  
tostring(parse_json(LocationDetails).city), State =  
tostring(parse_json(LocationDetails).state), Country =  
tostring(parse_json(LocationDetails).countryOrRegion)  
| project UserPrincipalName, UserId, City, State, Country  
| summarize PotentialImpossibleTravellInstances = count() by UserPrincipalName
```

Once your query is good, create the Schedule Query Rule in: **Sentinel** → **Analytics** → **Schedule Query Rule**

Analytics Rule Settings:

- Name:
- Description:
- Enable the Rule
- Use ChatGPT to set Mitre ATT&CK Framework Categories based on the query

1. **T1078 - Valid Accounts:** As attackers often use valid credentials to carry out malicious activities, an impossible travel detection could indicate the use of compromised credentials across multiple regions.
2. **T1021 - Remote Services:** Attackers might use remote services (e.g., RDP, SSH) to access systems from different geographic locations, which might be flagged by this query if unusual logins occur across multiple countries or cities.
3. **T1071.001 - Application Layer Protocol (Web):** If attackers use web-based login methods to gain access from various distant locations, this could be flagged by impossible travel.
4. **T1074 - Data Staged:** In cases where multiple locations are involved, attackers might be preparing for data exfiltration or staging, which could be detected as "impossible travel."
5. **T1059 - Command and Scripting Interpreter:** If the attacker is using a command-line interface or scripts to authenticate to multiple systems, sign-ins from multiple regions could occur within a short time span, potentially triggering the impossible travel pattern.

Summary:

The MITRE ATT&CK techniques most likely associated with this query are mainly related to **Credential Access** (T1078: Valid Accounts), **Initial Access** (e.g., T1071.001), and behaviors that indicate **suspicious use of valid accounts** across multiple geographic locations (such as lateral movement and data exfiltration). The query focuses on detecting anomalies in user sign-in locations, which could indicate the use of stolen or compromised credentials, an important aspect of many **cyberattack techniques**.

The specific categories that apply to the impossible travel detection are:

- **Credential Access:** T1078 - Valid Accounts
- **Initial Access:** T1071.001 - Application Layer Protocol: Web
- **Lateral Movement:** T1075 - Pass the Hash
- **Exfiltration:** T1041 - Exfiltration Over C2 Channel

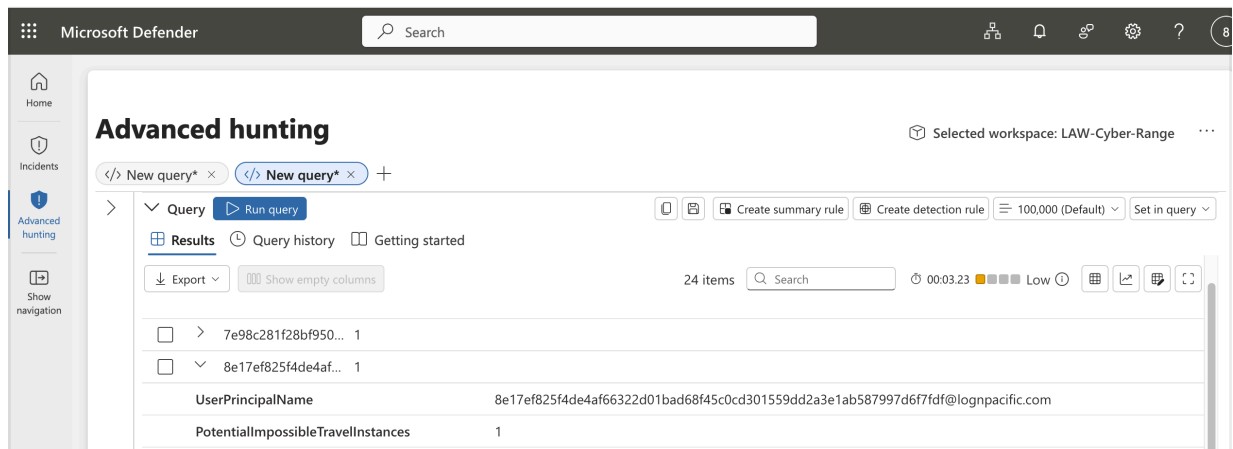
Message ChatGPT

- Run query every 4 hours
- Lookup data for last 5 hours (can define in query)
- Stop running query after alert is generated == Yes
- Configure Entity Mappings:
 - Account
 - ◆ Identifier: AadUserId, Value: UserId
 - ◆ Identifier: DisplayName, Value: UserPrincipalName
- Automatically create an Incident if the rule is triggered
- Group all alerts into a single Incident per 24 hours
- Stop running query after alert is generated (24 hours)
-

Part 2: Trigger Alert to Create Incident

Reminder: In order to generate the necessary logs for you to detect this activity,

simply create a new VM if you don't already have one, log into it, and then log into azure (<https://portal.azure.com>) from within your VM. This will trigger a new logon event in some random city on the East Coast (east us 2) somewhere.



Don't get confused between the [**Configuration → Analytics**] and [**Threat Management → Incidents**] sections.

Part 3: Work Incident

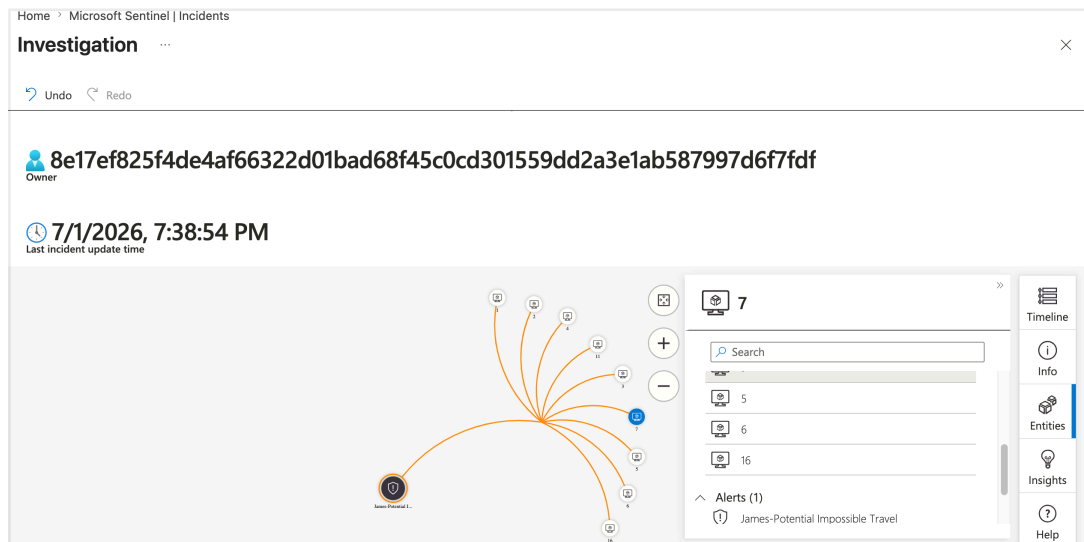
Work your incident to completion and close it out, in accordance with the NIST 800-61: Incident Response Lifecycle

Preparation

- Document roles, responsibilities, and procedures.
- Ensure tools, systems, and training are in place.

Detection and Analysis

- Identify and validate the incident.
 - Observe the incident and assign it to yourself, set the status to Active
 - Investigate the Incident by **Actions → Investigate** (sometimes takes time for entities to appear)



- Gather relevant evidence and assess impact.
 - Observe the output from the analytics rule and see which accounts have triggered the Impossible Travel alert
 - Investigate each individual account using a KQL query to see exactly where they have been logging into and make your own judgement if they are false or true positives. For example, if the user logged into two neighboring cities within a reasonable amount of time, this would be a false positive. However if someone has logged into Thailand, then Seattle, then Thailand all within 12 hours, this would be suspect.

KQL Analysis Query Spoiler

// Highlight to show query

// Investigate Potential Impossible Travel Instances

let TargetUserPrincipalName =

"8e17ef825f4de4af66322d01bad68f45c0cd301559dd2a3e1ab587997d6f7fdf@lo
gnpacific.com"; // Change to your target user (UserPrincipalName)

let TimePeriodThreshold = timespan(7d); // Change to how far back you want to
look

SigninLogs

| where TimeGenerated > ago(TimePeriodThreshold)

| where UserPrincipalName == TargetUserPrincipalName

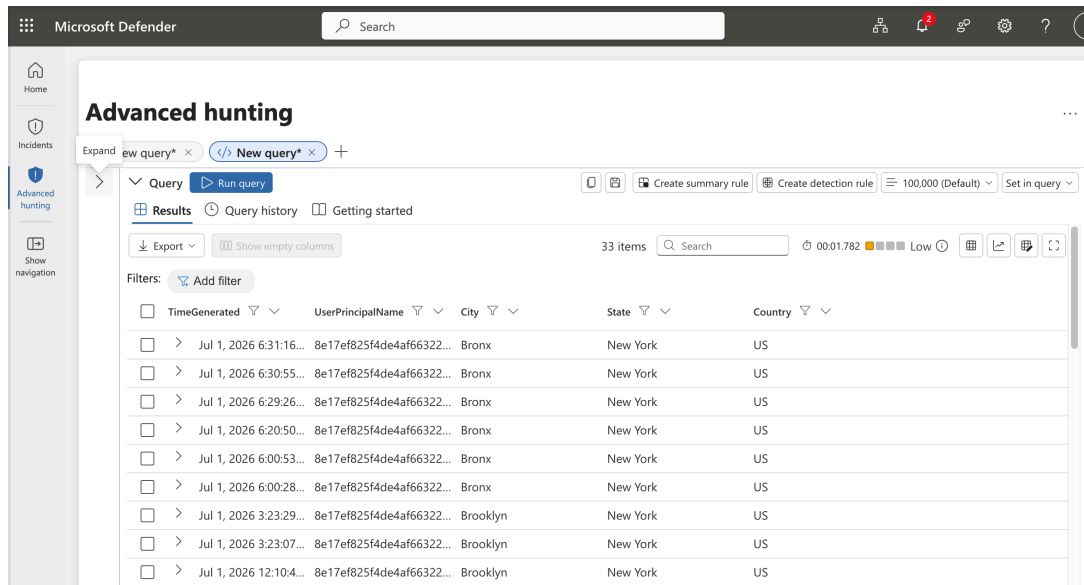
| project TimeGenerated, UserPrincipalName, City =

tostring(parse_json(LocationDetails).city), State =

tostring(parse_json(LocationDetails).state), Country =

tostring(parse_json(LocationDetails).countryOrRegion)

| order by TimeGenerated desc



Note:

The following observations were recorded from the instructor's VM device.

- Observe the different Users (UserPrincipalNames) logon patterns and take notes
 - josh.madakor@gmail.com logged in from x and y within Z time period: suspect
 - arisa_lognpacific@lognpacific.com logged in from a and b within C time period: normal
 - etc.

Containment, Eradication, and Recovery

- Isolate affected systems to prevent further damage.
 - In real life, depending on corporate policy and evidence, you might immediately disable the account in Entra ID (Azure Active Directory) and contact the user or the user's manager to investigate.
 - ◆ It was determined that the alert was a **BENIGN POSITIVE**. User ___ and logged into ___ and ___ within an ___ day time period, which should not be possible.
 - ◆ The user's account was disabled and management contacted.
- Remove the threat and restore systems to normal.
 - **There is currently no threat to remove, further action may be taken pending a decision from management.**
 - **It was determined that the alert was a TRUE Benign for both users.**

- User **josh.madakor@gmail.com** and logged into Tokyo and Osaka within an 3 hour time period, which is not common.
- The user's account was left intact due to expected behavior (not disabled)
 - ◆ If the logon behavior was unusual, account compromise may be possible.
 - ◆ Pivot to see what other activity the user has been doing. For example, you can look in the AzureActivity log:

AzureActivity

| where tostring(parse_json(Claims)["http://schemas.microsoft.com/identity/claims/objectidentifier"]) == "<azure user id/guid>"

Post-Incident Activities

- Update policies and tools to prevent recurrence.
 - You could do something like creating a **geo-fencing policy within azure** that prevents logins outside of certain regions. You can't do this in our environment, but it's something to keep in mind.
- Document findings and lessons learned.
 - Record your notes within the incident.

Closure

- Review and confirm incident resolution.
 - Review/observe your notes for the incident.
- Finalize reporting and close the case.
 - Close out the Incident within Sentinel as a "Benign Positive" (or whatever it was in your case)

Part 4: Cleanup (BE EXTREMELY CAREFUL HERE)

In Sentinel → Threat Management → Incidents, filter for closed incidents and delete YOUR incident

In Sentinel → Configuration → Analytics, delete YOUR analytics rule.

Be extremely careful to only delete YOUR Incident and Analytics Rule. Do not screw this up and delete someone else's, because it's possible. **Search by your name to narrow them down if you have to.**